

만료된 Access Token의 허니토큰화: 디셉션 기반 비인가 탐지 기법 연구

고남현*

*세종대학교 (학부생)

Honeytokenized Expired Access Tokens: A Cyber Deception-Based Method for Detecting Unauthorized Access

Nam-Hyun Ko*

*Sejong University (Undergraduate student)

요약

OAuth 2.0 인증 시스템에서 액세스 토큰(access token)의 사용이 사용자의 권한을 대변하는 주요 수단으로 활용됨에 따라, 토큰 탈취 공격의 보안 위험성은 증가하고 있다. 본 논문은 이러한 위협에 대응하기 위해, 만료된 액세스 토큰을 허니토큰(honeytoken)으로 전환하여 비인가 접근 시도를 능동적으로 탐지하는 디셉션 기반 보안 기법을 제안한다. 제안된 기법은 기존 인증 흐름을 변경하지 않으면서도 만료된 토큰을 탐지용 자산으로 재활용함으로써, 구분 불가능성(indistinguishability)과 비밀성(secretcy)이라는 허니오브젝트(honey objects) 설계 원칙을 충족한다. 또한 액세스 토큰의 사전 재발급 시스템을 도입하여 이전 토큰을 자동으로 허니토큰 DB에 등록하며, 공격자가 이를 사용할 경우 탐지되도록 설계되었다. Flask 기반 시뮬레이션 환경에서 구현된 시스템은 탐지 시나리오에서 정상 작동하였으며 오탐 없이 탐지 로그가 기록됨을 확인하였다. 제안 기법은 토큰 기반 인증 구조에 경량화된 디셉션 전략을 통합함으로써, 인증 자산 보호를 위한 실용적 방어 체계를 제시한다.

I. 서론

OAuth 2.0 환경에서 액세스 토큰 탈취는 공격자가 인증 과정을 우회하거나 정상 사용자로 위장해 시스템에 접근하게 만드는 주요 보안 위협 중 하나다. 실제로 GitHub OAuth 통합 토큰 유출 사건(2022)과 Mailchimp API 침해 사고(2023)에서는 액세스 토큰의 탈취가 대규모 무단 접근과 피싱 공격으로 이어진 바 있다. 이는 단일 토큰 유출이 전체 시스템의 보안에 심각한 영향을 미칠 수 있음을 보여준다.

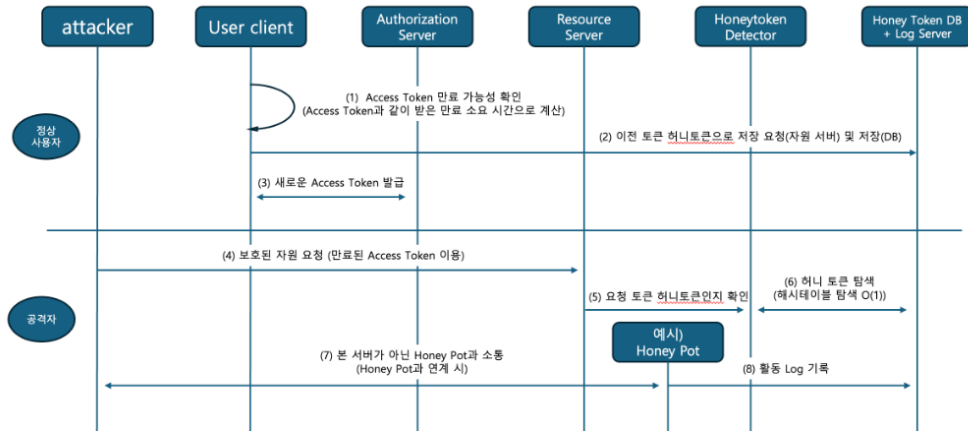
최근 공격을 유도하고 탐지할 수 있는 사이버 디셉션(cyber deception) 기술이 주목받고 있으며, 특히 허니토큰은 정상적인 인증 데이터처럼 위장된 가짜 정보를 통해 비정상 접근을 식별하는 기법으로 활용되고 있다.

본 논문은 만료된 액세스 토큰을 허니토큰으로 전환하여, 공격 시도 시 자동으로 탐지할 수 있는 능동적 방어 전략을 제안한다.

II. 관련 연구 동향

Juels[1]은 정보 보안 환경에서 허니오브젝트의 핵심 설계 원칙으로 '구분 불가능성'과 '비밀성'을 제시했다. 허니토큰은 공격자에게 노출되는 실제 데이터와 구별되지 않아야 하며, 그 존재 여부는 서버 내부 로직을 통해서만 판단 가능해야 한다. 이 설계 기준은 허니토큰이 탐지를 회피하며 인증 흐름 내에 자연스럽게 통합되도록 하기 위한 것이다. 본 연구는 만료된 액세스 토큰을 삭제하지 않고 허니토큰으로 전환하여, 외형상 정상 토큰과 동일하게 유지함으로써 Juels가 제시한 허니오브젝트의 설계 조건을 충족시킨다.

Celik 등[2]은 능동 방어 전략(active defense)의 일환으로 허니토큰이 다양한 실제 시스템에 적용되고 있음을 사례를 통해 분석하였다. 특히 이메일 주소, 클라우드 API 키, 인증 쿠키 등과 같은 민감한 자격 정보를 위장한 허니토큰은 비인가 접근을 실시간으로 탐지하고 공격자의



[그림 1] 공격자의 비인가 접근 시나리오

행위를 추적하는 데 효과적으로 사용된다. 본 연구는 이러한 접근을 확장하여, OAuth 2.0 인증 구조 내에서 만료된 토큰을 탐지용 자산으로 재활용하는 방식으로 능동 방어를 구현한다는 점에서 기술적 연속성과 현실 적용 가능성을 동시에 갖는다.

III. 제안 기법

본 논문은 OAuth 2.0 기반 인증 환경에서 만료된 액세스 토큰을 허니토큰으로 전환하여, 공격자의 비인가 접근을 탐지하는 디셉션 기반 방어 기법을 제안한다. 본 기법은 기존 보안 방식이 액세스 토큰의 유효성 검증에만 집중한 것과 달리, 이미 만료된 토큰 자체를 능동적 탐지 자산으로 활용한다는 점에서 차별성을 지닌다.

3.1 핵심 아이디어

일반적으로 OAuth 2.0 시스템은 액세스 토큰의 유효성을 단순히 서버 측 검증 절차를 통해 확인하고, 만료된 경우에는 단순히 이를 거부하는 방식으로 보안을 유지한다. 그러나 공격자가 탈취한 토큰을 최초로 사용할 때에는 그 토큰의 유효 여부를 정확히 인지하지 못할 가능성이 존재하며, 이로 인해 만료된 토큰이 인증 요청에 사용될 수 있다. 이 점에 착안하여, 정상 사용자의 만료된 토큰 사용을 사전에 방지하고, 재발급 시 기존 토큰을 자동으로 허니토큰으로 전환하여 탐지 대상에 포함하는 구조를 제안한다. 이로써 공격자는 탈취한 만료 토큰을 아무런 제약 없이 사용하는 반면, 시스템은 이를 탐지 트리거로 인식하여 의심 접근을 신속하고

지속적으로 식별할 수 있다. 단, 공격자의 허니토큰 식별 우회 가능성은 본 논문에서 배제한다.

3.2 시나리오

OAuth 2.0 인증 흐름에서는 액세스 토큰이 만료된 이후 리프레시 토큰(refresh token)을 통해 새로운 토큰을 발급 받거나, 만료되기 이전 일정 시점에서 미리 재발급이 이뤄질 수 있다. 후자의 경우, 액세스 토큰 갱신 시 이전 토큰을 무효화하지 않아 짧은 시간 동안 두개의 토큰이 존재할 수 있다. 본 연구에서는 이러한 상황을 통제하기 위해, 액세스 토큰의 사전 재발급 시스템을 도입하고, 새로운 토큰이 발급되는 시점에 기존 토큰을 즉시 허니토큰으로 등록하는 기법을 제안한다. 이후 해당 토큰을 이용한 접근 요청이 발생한 경우, 공격자의 행위로 간주되어 탐지 로그가 생성되고 대응이 가능해진다.

IV. 디셉션 시스템 구조

4.1 시스템 구조 및 동작 흐름

시스템은 "[그림 1]"의 시스템의 설계 구조도 흐름으로 동작한다:

1) 액세스 토큰 재발급 감지 및 허니토큰 등록: 클라이언트가 토큰 사전 재발급 시스템을 활용해 권한 서버에 새로운 토큰을 요청할 경우 새 토큰을 발급하고, 자원 서버에 이전 토큰을 허니토큰으로 전환하는 요청을 보낸다.

2) 자원 서버의 허니토큰 등록 및 토큰 검사:

자원 서버는 전달받은 만료 토큰을 허니토큰 탐지 모듈에 저장하는 요청을 하며, 추후 클라이언트 요청 시 해당 토큰이 허니토큰인지 선 검사한다. 탐지된 경우, 요청을 차단하고 탐지 로그를 생성한다. 탐지되지 않은 경우, 권한 서버에 introspection API를 통해 토큰의 유효성을 확인하고, 보호된 자원에 대한 접근을 처리한다.

3) 비인가 접근 탐지 및 로깅: 공격자가 탈취한 만료 토큰을 통해 자원에 접근을 시도하면, 허니토큰 탐지 모듈은 해시 기반 탐색을 통해 해당 토큰을 탐지하고, 로그를 기록한다. (현재 실험 단계에서는 구조 단순화를 위해 허니토큰 탐지 및 기록 모듈을 자원 서버 내부에 통합한 형태로 구성하였으며, 실서비스 환경에서는 독립되게 분리하여 운영이 가능하다.)

4.2 시스템 기능 검증 실험 결과

Flask 기반으로 구축된 시뮬레이션 환경에서 기능 검증 실험을 수행하였다. 실험은 정상 토큰과 만료된 토큰을 이용한 접근 요청 시나리오를 기반으로 진행되었다. 모든 시나리오에서 기대한 탐지 및 차단 로직이 정상적으로 작동하였으며, 오탐은 발생하지 않았다. 또한 디버깅 페이지를 통해 탐지된 허니토큰 접근 로그를 시각적으로 확인할 수 있었다. 로그는 토큰 값, 사용자명, 접근 시각, 탐지 이유가 기록되며, 탐지 정확성과 대응의 실시간성이 확보되었음을 입증하였다. "[표 1]"은 기능 검증 시나리오 결과이다.

설명	기대동작	결과
정상 토큰으로 자원 접근	접근 허용	정상 처리
만료된 토큰으로 접근	허니토큰 탐지	접근 거부
리프레시 후 이전 토큰 탐지 시도	탐지 및 로깅	정상 기록
허위 토큰 (introspection 실패)	무효 처리	접근 거부

[표 1] 기능 검증 실험 시나리오 결과

V. 결론

본 연구는 OAuth 2.0 기반 인증 환경에서 발생할 수 있는 액세스 토큰 탈취 및 재사용 위협에 대응하기 위한 방안으로, 만료된 액세스 토큰을 허니토큰으로 전환하여 비인가 접근을 능동적으로 탐지하는 디셉션 기반 보안 기법을 제안하였다. 제안된 시스템은 기존 인증 흐름의

구조를 변경하지 않으면서도 허니토큰을 통해 위협 행위를 유도 및 식별할 수 있도록 설계되었으며, 실제 구현을 통해 탐지 로직의 작동 가능성을 확인하였다.

향후 연구에서는 다음과 같은 방향으로 확장이 가능하다. 첫째, 기능적 구현에 초점을 맞춘 초기 단계에서 벗어나서 성능 평가 항목을 정량화 하여 평가 지표를 수립할 예정이다. 둘째, 리프레시 토큰 탈취, 내부자 공격, 고도화된 재사용 시나리오 등 보다 현실적인 위협 모델을 반영한 구조로 확장함으로써, 실환경에 가까운 디셉션 탐지 체계로 발전시킬 수 있다. 셋째, 탐지 이후 공격자의 행위 분석 및 허니팟(honeypot) 연계를 통해, 적극적인 탐지를 넘어서 적응형 탐지 정책과 자동 대응 시나리오 생성이 가능한 지능형 방어 체계로 발전시키는 것을 목표로 한다.

궁극적으로는 다양한 인증 자산에 대응 가능한 확장성 있고 유연한 디셉션 기반 실시간 방어 체계를 구축하여, 다양한 인증 프로토콜 환경에 적용 가능한 실용적 기술로 발전시킬 계획이다.

[참고문헌]

- [1] A. Juels, "A bodyguard of lies: The use of honey objects in information security", Proceedings of the 19th ACM Symposium on Access Control Models and Technologies (SACMAT'14), pp 1-4, June 2014.
- [2] Y. Celik, S.Mayers, N. Novikov, N.A. Howell, K. Giani, Y.S. Konatham, M. Williams, and S. Goel, "Honeypots and honeytokens in active defense", Proceedings of the 18th Annual Symposium on Information Assurance (ASIA '23), University at Albany, State University of New York, pp.1-8, Feb 2024.